

There are many tools available for **Vulnerability Assessment and Penetration Testing (VAPT)** of mobile apps. You can use a combination of automated and manual tools to perform preliminary tests on your apps before sending them to your security team.

What is VAPT?

VAPT is a systematic process of identifying and exploiting security weaknesses in a system. It consists of two main parts:

- **Vulnerability Assessment (VA):** This involves scanning and analyzing an application for known security flaws. This is often done using automated tools.
- **Penetration Testing (PT):** This is a simulated cyberattack performed by a security expert (an ethical hacker) to test the application's defenses. It involves exploiting the vulnerabilities found during the VA phase to determine the potential impact.

Recommended VAPT Tools for Mobile Apps

You'll need a different set of tools depending on whether you're performing static or dynamic analysis.

Static Analysis Tools (SAST)

Static Analysis Security Testing (SAST) involves analyzing an application's source code or binary without running it. These tools are great for catching issues early in the development lifecycle.

- **MobSF (Mobile Security Framework):** This is an excellent all-in-one open-source tool for both Android and iOS apps. It performs static and dynamic analysis, offering a comprehensive overview of potential security risks.
- **QARK (Quick Android Review Kit):** An open-source tool specifically for Android apps. It analyzes the code for security flaws and provides detailed reports with remediation advice.
- **JADX:** This is a command-line tool and GUI for decompiling Android APKs into Java source code, which is essential for manual code review and static analysis.
- **Ghidra:** A powerful, free, and open-source reverse engineering framework developed by

the NSA. It's great for analyzing decompiled binaries of both Android and iOS applications.

Dynamic Analysis Tools (DAST)

Dynamic Analysis Security Testing (DAST) involves testing the running application on an emulator or a physical device. These tools can help you find vulnerabilities that only appear during runtime, such as insecure data transmission or improper session handling.

- **MobSF:** As mentioned above, MobSF also has dynamic analysis capabilities, allowing you to test the app in a controlled environment.
- **Burp Suite:** This is an industry-standard proxy tool used to intercept, inspect, and modify network traffic between your mobile app and its server. It's a must-have for API and network security testing.
- **Frida:** A dynamic instrumentation toolkit that lets you inject code into running processes. It's widely used by security researchers to bypass security controls like root detection and SSL pinning.
- **Drozer:** An open-source tool for testing Android apps by interacting with the Android Inter-Process Communication (IPC) system. It can identify vulnerabilities like insecure data exposure and misconfigurations.
- **OWASP ZAP (Zed Attack Proxy):** Another free and open-source proxy tool that is a popular choice for both beginners and experienced penetration testers. It can be used to perform automated scans and manual testing.

Using a combination of these tools will help you conduct thorough preliminary VAPT on your mobile apps, allowing you to fix common issues and deliver a more secure product to your security team.